TechStart Inc.

ISO/IEC 27001:2022 Cloud Migration — Full Programme Pack

Company	TechStart Inc. (500 employees) — B2B SaaS / Cloud Services
Scope	On-premises to AWS cloud migration — 5M+ customer records, 2 TB
Frameworks	ISO/IEC 27001:2022 (Annex A), ISO/IEC 27002:2022, NIST CSF, GDPR
Classification	CONFIDENTIAL
Date	Q3 2024 — March 2026
Prepared by	Tejaswini Dondeti
Package contents	1. Risk Assessment Report 2. Information Security Policy 3. Access Control Policy 4. Data Cla

Portfolio Sample — for demonstration of GRC capability. Not for distribution.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Table of Contents

Section 1	ISO 27001:2022 Risk Assessment Report
Section 2	Information Security Policy
Section 3	Access Control Policy
Section 4	Data Classification & Handling Policy
Section 5	Risk Register & 5×5 Heat Map (landscape)
Section 6	Remediation Tracker (landscape)
Section 7	Statement of Applicability (landscape)

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 1 — ISO 27001:2022 Risk Assessment Report

Cloud Migration Project — AWS

TECHSTART INC

B2B SaaS / Cloud Services

ISO 27001:2022 Risk Assessment

Cloud Migration Project — AWS

Document:

ISO 27001 Risk Assessment Report

Company:

TechStart Inc (500 employees)

Scope:

On-premises to AWS Cloud Migration — 5M+ customer records

Frameworks:

ISO 27001:2022 (Annex A) | NIST CSF

Date:

March 2026

Classification:

CONFIDENTIAL

1. EXECUTIVE SUMMARY

TechStart Inc is a B2B SaaS company serving enterprise clients with a customer database containing over 5 million records. The company is migrating this critical database from on-premises infrastructure to Amazon Web Services (AWS) to improve scalability, reduce operational costs, and meet growing client demands. Simultaneously, TechStart is pursuing ISO 27001:2022 certification to satisfy enterprise client security requirements and demonstrate a mature information security posture.

This risk assessment identifies critical assets involved in the migration, evaluates key risks using a 5x5 likelihood-impact matrix, and maps security controls to ISO 27001:2022 Annex A and the NIST Cybersecurity Framework. The goal is to ensure that the migration is executed securely, with risks reduced to acceptable levels, while building the foundation for ISO 27001 certification.

2. RISK SCORING METHODOLOGY

Before identifying risks, we need a consistent way to measure them. We use a 5x5 matrix where Risk Score = Likelihood x Impact.

2.1 Likelihood Scale

Score

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Rating

What it means

1

Rare

Less than once in 5 years. Example: A zero-day exploit targeting your specific tech stack.

2

Unlikely

Once every 2-5 years. Example: A disgruntled employee attempts data theft.

3

Possible

Once per year. Example: A phishing email successfully tricks an employee into revealing credentials.

4

Likely

Multiple times per year. Example: Cloud misconfiguration due to rapid deployment without review.

5

Almost Certain

Monthly or more often. Example: Employees reusing weak passwords across services.

2.2 Impact Scale

Score

Rating

What it means for TechStart

1

Negligible

< $10K loss. No customer impacts. Internal inconvenience only.

2

Minor

$10K-$100K loss. Brief service disruption. A few customers notice.

3

Moderate

$100K-$500K loss. Service degraded for hours. Media coverage possible.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

4

Major

$500K-$2M loss. Extended outage. Customer churn. Regulatory inquiry.

5

Severe

> $2M loss. Massive data breach. Lawsuits. Loss of ISO certification. Business survival at risk.

2.3 Risk Rating Matrix

■ How to read this matrix

Find where Likelihood (across the top) meets Impact (down the side). The number in the cell is your Risk Score. Green (1-4) = Low risk, accept it. Blue (5-9) = Medium risk, monitor and reduce. Orange (10-14) = High risk, take action soon. Red (15-25) = Critical risk, immediate action required. In ISO 27001, you MUST document how you treat every risk that is above your risk appetite (usually anything Medium or above).

3. CRITICAL ASSET IDENTIFICATION

The first step in any ISO 27001 risk assessment is identifying the assets that need protection. An asset is anything of value to the organization. We focus on assets directly involved in or affected by the cloud migration.

Asset 1: Customer Database (Primary)

FIELD

VALUE

Name

Customer PII Database

Type

Database

Classification

Critical

Owner

VP of Engineering

Environment

Production (migrating from on-prem to AWS RDS)

Description

Company has a SQL database that stores more than 5 million customer records, including names, emails, billing addresses, payment information, and how customers use the product. This is the most valuable data asset in the company and the primary target of the migration. Right now, it runs on a physical Dell server in the company's data center, but it will be moved to a managed cloud database service with backup and redundancy on AWS.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Asset 2: AWS Cloud Account (Root & IAM)

FIELD

VALUE

Name

AWS Production Account

Type

Cloud Account

Classification

Critical

Owner

Director of Cloud Infrastructure

Environment

Production

Description

The company has a main AWS cloud account where all their live systems will run after the migration. This account contains the network, servers, databases, storage, user permissions, encryption keys, logging systems, and security monitoring tools. The main root account has full control over everything. The company uses IAM to manage access for more than 45 engineers with different permission levels.

Asset 3: Data Migration Pipeline

FIELD

VALUE

Name

AWS Database Migration Service (DMS) Pipeline

Type

Application

Classification

High

Owner

Lead Database Engineer

Environment

Production

Description

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

The company is using a special AWS service to move their database from their office servers to the cloud. This system copies the data from the old PostgreSQL database to the new AWS database. It uses a secure network connection between the company data center and AWS. During the migration, it continuously copies any new data changes so that both databases stay synchronized. In total, about 2 terabytes of data will be transferred.

4. RISK IDENTIFICATION & ASSESSMENT

Now that we know WHAT we are protecting (our 3 critical assets), we identify WHAT COULD GO WRONG. Each risk is evaluated for likelihood and impact, producing a risk score that determines priority.

Risk 1: Unauthorized Access to Customer Database During Migration

FIELD

DETAILS

Title

Unauthorized Access to Customer Database During Cloud Migration

Category

Data Protection

Status

Open

Likelihood

4 — Likely

Impact

5 — Severe

Risk Score

20 (4 × 5) — CRITICAL

Related Asset

Customer PII Database

Owner

VP of Engineering

Description

When the company moves its database from its own servers to the AWS cloud, there is a risk that sensitive customer data could be stolen or seen by unauthorized people. This data includes personal information like names, emails, addresses, and payment details. The data could be exposed if the network connection is not encrypted, if employees have too much access, if temporary login credentials are not removed, or if backup files are stored without encryption. If such a data breach happens, the company could face privacy law penalties, financial fines, loss of customers, and damage to its reputation.

Risk 2: AWS Account Compromise via Misconfigured IAM

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

FIELD

DETAILS

Title

AWS Account Compromise Through Misconfigured IAM Policies

Category

Access Control

Status

Open

Likelihood

4 — Likely

Impact

5 — Severe

Risk Score

20 (4 × 5) — CRITICAL

Related Asset

AWS Production Account

Owner

Director of Cloud Infrastructure

Description

AWS access permissions might be set incorrectly, giving engineers or system accounts more access than they need. This often happens during system migrations when teams quickly give broad permissions to fix access problems and forget to remove them later. Because of this, engineers could accidentally delete important systems, attackers could steal data if an account is hacked, the main root account might be used unsafely, or secret access keys might be stored inside application code where attackers can find them.

Risk 3: Data Loss or Corruption During Migration

FIELD

DETAILS

Title

Data Loss or Corruption During Database Migration to AWS

Category

Availability

Status

Open

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Likelihood

3 — Possible

Impact

5 — Severe

Risk Score

15 (3 × 5) — CRITICAL

Related Asset

Data Migration Pipeline (AWS DMS)

Owner

Lead Database Engineer

Description

While the company is transferring about 2 terabytes of customer data to AWS using a migration tool, some data might be lost, copied twice, damaged, or stored incorrectly. This can happen because of technical problems such as different data formats, network interruptions, delays in data replication, database structure differences, or problems handling very large data fields. If the 5 million customer records become damaged, the company may face billing mistakes, system failures, and difficulty providing services to customers.

Risk 4: Compliance Violation Due to Data Residency Non-Compliance

FIELD

DETAILS

Title

Data Residency & Privacy Compliance Violation Post-Migration

Category

Compliance

Status

Open

Likelihood

3 — Possible

Impact

4 — Major

Risk Score

12 (3 × 4) — HIGH

Related Asset

Customer PII Database & AWS Account

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Owner

Data Protection Officer

Description

After the company moves its customer data to AWS, the data might be stored or processed in cloud locations that are not allowed by privacy laws or customer contracts. Some regulations require that certain data must stay in specific geographic regions. If the data is stored in the wrong location, the company could face fines, lose customers, or fail security certification requirements.

Risk 5: Extended Service Outage During Cutover

FIELD

DETAILS

Title

Extended Production Outage During Database Cutover Window

Category

Availability

Status

Open

Likelihood

3 — Possible

Impact

4 — Major

Risk Score

12 (3 × 4) — HIGH

Related Asset

Data Migration Pipeline & Customer Database

Owner

VP of Engineering

Description

When the company switches its SaaS application from the old database server to the new AWS cloud database, some technical problems might happen. The application may not connect properly, the network settings may not work well in the cloud, switching back to the old system might fail, or the migration may take longer than planned. If the system stays offline for too long, customers cannot use the service, and the company may break its service agreement and face penalties.

5. RISK SUMMARY TABLE

#

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Risk Title

L

I

Score

Rating

Category

R-01

Unauthorized Access to Customer DB

4

5

20

CRITICAL

Data Protection

R-02

AWS IAM Misconfiguration

4

5

20

CRITICAL

Access Control

R-03

Data Loss/Corruption in Migration

3

5

15

CRITICAL

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Availability

R-04

Data Residency Non-Compliance

3

4

12

HIGH

Compliance

R-05

Extended Cutover Outage

3

4

12

HIGH

Availability

6. SECURITY CONTROLS TO MITIGATE RISKS

Each risk identified above must have a corresponding control (or set of controls) to reduce the risk to an acceptable level. Below are 5 controls mapped to ISO 27001:2022 Annex A and NIST CSF.

Control 1: Encryption at Rest and In Transit (Mitigates Risk R-01)

FIELD

DETAILS

Name

End-to-End Data Encryption (AES-256 at rest, TLS 1.3 in transit)

Framework

ISO 27001:2022

Reference

Annex A 8.24 — Use of cryptography | NIST CSF PR.DS-1, PR.DS-2

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Effectiveness

Not Tested (to be validated post-implementation)

Frequency

Continuous

Owner

VP of Engineering

Description

All customer data stored in the cloud database must be strongly encrypted. Data must also be encrypted when it moves between systems. Only secure connections are allowed. Encryption keys must be rotated regularly, and all key activities must be logged for security monitoring.

Control 2: Least-Privilege IAM with MFA Enforcement (Mitigates Risk R-02)

FIELD

DETAILS

Name

Least-Privilege IAM Policies with Mandatory MFA

Framework

ISO 27001:2022

Reference

Annex A 5.15 — Access control | A 5.16 — Identity management | A 8.5 — Secure authentication | NIST CSF PR.AC-1, PR.AC-4

Effectiveness

Not Tested

Frequency

Continuous (with quarterly access reviews)

Owner

Director of Cloud Infrastructure

Description

Give every user only the permissions they need to do their job in AWS. Protect the root account with strong security. Require multi-factor authentication for logins. Avoid permanent access keys and use temporary credentials instead. Regularly review user access and remove unnecessary permissions.

Control 3: Automated Backup & Data Validation (Mitigates Risk R-03)

FIELD

DETAILS

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Name

Pre-Migration Backup with Automated Data Integrity Validation

Framework

ISO 27001:2022

Reference

Annex A 8.13 — Information backup | A 8.14 — Redundancy | NIST CSF PR. IP-4

Effectiveness

Not Tested

Frequency

Continuous (automated checks during and after migration)

Owner

Lead Database Engineer

Description

Before moving the database to the cloud, create a full backup of the existing database. During migration, compare the data in the old and new databases to make sure nothing is missing or changed. After migration, run several checks to confirm the data is correct. Keep the old database in read-only mode for 30 days so the company can return to it if something goes wrong.

Control 4: AWS Region Restriction & Data Residency Policy (Mitigates Risk R-04)

FIELD

DETAILS

Name

AWS Region Restriction with SCP-Enforced Data Residency

Framework

ISO 27001:2022

Reference

Annex A 5.34 — Privacy and protection of PII | A 5.31 — Legal and regulatory requirements | NIST CSF ID. GV-3

Effectiveness

Not Tested

Frequency

Continuous (SCP enforcement is real-time)

Owner

Data Protection Officer

Description

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

The company must control where customer data is stored in AWS. Resources can only be created in approved regions. Systems must block any attempt to create resources in other regions. Data replication across regions must be restricted. Logs must stay in the correct region. The company must also document where customer data is allowed to be stored and review this policy regularly.

Control 5: Migration Cutover Runbook with Rollback Plan (Mitigates Risk R-05)

FIELD

DETAILS

Name

Documented Cutover Runbook with Tested Rollback Procedure

Framework

ISO 27001:2022

Reference

Annex A 5.30 — ICT readiness for business continuity | A 8.14 — Redundancy | NIST CSF PR. IP-9, RC.RP-1

Effectiveness

Not Tested

Frequency

Annual (runbook review) + before each migration phase

Owner

VP of Engineering

Description

Before switching the database to the cloud, the team should create a detailed step-by-step guide. This guide explains what to check before the switch, how to perform the switch, when to cancel the switch if problems happen, and how to return to the old system. The team should also practice the process at least two times before doing it in the real system.

7. CONTROL-TO-RISK MAPPING MATRIX

This matrix shows which controls address which risks, providing traceability for ISO 27001 auditors.

Control

R-01

R-02

R-03

R-04

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

R-05

C-01: Encryption

PRIMARY

C-02: IAM + MFA

SECONDARY

PRIMARY

C-03: Backup & Validation

PRIMARY

SECONDARY

C-04: Region Restriction

PRIMARY

C-05: Cutover Runbook

SECONDARY

PRIMARY

8. RISK TREATMENT PLANS

A Risk Treatment Plan (RTP) is the action plan that takes a risk from 'identified' too 'managed'. While the risk register tells you WHAT the risks are and the controls tell you HOW to reduce them, the treatment plan tells you WHO will do WHAT, by WHEN, with WHAT budget, and HOW you will know it worked.

Risk Treatment Plan 1: Unauthorized Access to Customer Database (R-01)

FIELD

DETAILS

Risk ID

R-01

Risk Title

Unauthorized Access to Customer Database During Cloud Migration

Inherent Risk Score

20 (Critical) — Likelihood 4 × Impact 5

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Treatment Option

MITIGATE — Reduce both likelihood and impact through layered security controls

Target Residual Score

8 (Medium) — Target Likelihood 2 × Impact 4

Treatment Owner

VP of Engineering

Approver

CISO

Treatment Actions

Before migrating the database, the company will enable strong AES-256 encryption on the cloud database using its own encryption keys managed in AWS. All database connections must use secure TLS 1.3 encryption, and any unencrypted connections will be disabled. The database will also be protected at the network level by allowing access only from approved application servers inside the private cloud network, and the database will not have a public internet address. Migration traffic will use a private AWS connection to keep it secure. The company will also deploy a data loss prevention tool to scan cloud storage and system logs to detect if any personal customer data is accidentally exposed. If sensitive data is found outside approved locations, automatic alerts will notify the security team. Before the migration starts, a security penetration test will be performed to check for vulnerabilities in the database and migration process, and all serious security issues must be fixed before continuing. Finally, database activity monitoring will be enabled to record every query made to the customer database, and real-time alerts will be triggered if unusual behavior is detected, such as large data downloads, access from unknown IP addresses, or database activity outside normal working hours.

Risk Treatment Plan 2: AWS IAM Misconfiguration (R-02)

FIELD

DETAILS

Risk ID

R-02

Risk Title

AWS Account Compromise Through Misconfigured IAM Policies

Inherent Risk Score

20 (Critical) — Likelihood 4 × Impact 5

Treatment Option

MITIGATE — Reduce likelihood through strict access governance and automated policy enforcement

Target Residual Score

5 (Medium) — Target Likelihood 1 × Impact 5

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti@gmail.com
Tejaswini Dondeti — Portfolio Sample

Treatment Owner

Director of Cloud Infrastructure

Approver

CISO

Treatment Actions

Lock down the AWS root account by enabling hardware multi-factor authentication using a YubiKey, removing all root access keys, storing the root credentials in a sealed envelope inside a physical safe, and documenting a special emergency procedure for using the root account. Create role-based access policies in AWS for four groups: Developers, who can read EC2 and S3 resources and deploy to staging environments; DBAs, who can access the database service and encryption keys; DevOps engineers, who can manage compute resources and deployments; and the Security team, who can view identity management settings and security logs. Each policy must specify exact resources instead of using broad permissions.

Require multi-factor authentication for every AWS user by applying a rule that blocks access if MFA is not used and give a hardware MFA device such as a YubiKey to all engineers so that no one can log in without this extra security step. Remove all long-term access keys and change every application and automation pipeline to use IAM roles with temporary credentials instead and run a weekly report to make sure no new permanent access keys have been created.

Finally, deploy AWS IAM Access Analyzer to continuously monitor permissions, detect overly broad access rights or unused permissions, identify any access granted to external accounts, send alerts if a policy allows public or cross-account access, and review all user permissions with team leaders every three months.

Risk Treatment Plan 3: Data Loss/Corruption During Migration (R-03)

FIELD

DETAILS

Risk ID

R-03

Risk Title

Data Loss or Corruption During Database Migration to AWS

Inherent Risk Score

15 (Critical) — Likelihood 3 × Impact 5

Treatment Option

MITIGATE — Reduce likelihood through rigorous validation and reduce impact through verified rollback capability

Target Residual Score

6 (Medium) — Target Likelihood 2 × Impact 3

Treatment Owner

Lead Database Engineer

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.dev/portfolio

Approver

VP of Engineering

Treatment Actions

Create and verify a full backup of the database before migration, store the backup in two places (a local network storage system and an encrypted cloud storage bucket in Amazon S3), and confirm the backup works by restoring it to a test server and comparing the total number of records with the production database. Build an automated data validation system using Python and SQL scripts that compares the source and target databases by checking the total number of rows in each table, verifying the sum and count of all numeric columns such as billing amounts, generating MD5 hashes of combined key columns in batches of 10,000 rows to confirm data integrity, validating foreign key relationships between tables, and confirming that text fields containing international characters use the correct character encoding.

Run three complete migration practice runs in a staging environment before the real production migration, ensure that every rehearsal achieves a 100% data validation success rate, and document and fix any failures discovered during testing. Configure AWS Database Migration Service with validation enabled and partial validation for very large tables and set monitoring alerts in Amazon CloudWatch to notify the team if the replication delay becomes longer than 60 seconds.

Finally, keep the original on-premises database running in read-only mode for 30 days after the migration so it can serve as a backup system, and define a clear rollback rule stating that if data validation errors exceed 0.01% of all records at any time, the system must immediately switch back to the on-premises database.

Risk Treatment Plan 4: Data Residency Compliance Violation (R-04)

FIELD

DETAILS

Risk ID

R-04

Risk Title

Data Residency & Privacy Compliance Violation Post-Migration

Inherent Risk Score

12 (High) — Likelihood 3 × Impact 4

Treatment Option

MITIGATE — Reduce likelihood through technical enforcement (SCPs) and reduce impact through proactive compliance documentation

Target Residual Score

4 (Low) — Target Likelihood 1 × Impact 4

Treatment Owner

Data Protection Officer

Approver

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Chief Legal Officer

Treatment Actions

Conduct a Data Privacy Impact Assessment (DPIA) following GDPR Article 35 by mapping all customer data flows, including where personally identifiable information (PII) originates, where it is processed, where it is stored, and who can access it, and identify all AWS services that will handle this data. Create a Data Residency Matrix that links each customer segment to the regions required by contracts and regulations, for example, EU enterprise clients must have their PII stored only in eu-west-1 to comply with GDPR, and get the matrix reviewed and signed off by the Legal team.

Implement AWS Service Control Policies (SCPs) to block any API calls that try to create resources in regions not approved for the data, ensuring that even administrators cannot override these restrictions, and test it by trying to create an EC2 instance in an unapproved region (it should fail).Set up AWS Config rules to continuously monitor all resources for compliance with approved regions, and enable automated responses: if a resource is in the wrong region, it triggers an alert via SNS to the Data Protection Officer (DPO) and runs a Lambda function that tags the resource for review.

Finally, update all enterprise client Data Processing Agreements (DPAs) to explicitly specify the approved AWS regions for data storage and processing, including a contractual requirement to notify clients within 48 hours if there are any changes to data residency.

Risk Treatment Plan 5: Extended Cutover Outage (R-05)

FIELD

DETAILS

Risk ID

R-05

Risk Title

Extended Production Outage During Database Cutover Window

Inherent Risk Score

12 (High) — Likelihood 3 × Impact 4

Treatment Option

MITIGATE — Reduce likelihood through rehearsals and reduce impact through rapid rollback capability

Target Residual Score

4 (Low) — Target Likelihood 2 × Impact 2

Treatment Owner

VP of Engineering

Approver

CTO

Treatment Actions

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Write a detailed cutover runbook that lists every command to run, who is responsible for each step, how long each step should take, the criteria for success, and screenshots of expected outputs, and include a decision tree for each step defining when to proceed or abort, then have three engineers independently review it. Conduct the first rehearsal in the staging environment using a full copy of production data, time each step, identify bottlenecks, and document any issues, aiming to complete the cutover within 45 minutes, and fix all problems found.

Conduct a second rehearsal in staging with a planned rollback trigger at the midpoint, verify that the rollback procedure restores the system to a fully operational state without any data loss, time the rollback, and aim to complete it within 15 minutes. Set up a real-time monitoring dashboard using CloudWatch and a custom Grafana board to display application error rates, database connection counts, query latencies, DMS replication lag, and the customer-facing status page, and define automated rollback triggers if error rate exceeds 5% for 5 minutes or latency exceeds 2 seconds for 10 minutes.

Prepare a customer communication plan that includes a 7-day advance notice email, a 24-hour reminder, real-time status updates on a status page during the cutover, and a post-cutover confirmation email, and assign a Customer Success led to handle real-time escalations during the cutover window.

9. RISK TREATMENT SUMMARY

This table provides a quick reference of all risk treatment outcomes, showing how each risk moves from its inherent score to the target residual score after treatment.

Risk

Title

Inherent

Rating

Target

Rating

Option

R-01

Unauth. DB Access

20

Critical

8

Medium

Mitigate

R-02

IAM Misconfig.

20

Critical

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

5

Medium

Mitigate

R-03

Data Corruption

15

Critical

6

Medium

Mitigate

R-04

Data Residency

12

High

4

Low

Mitigate

R-05

Cutover Outage

12

High

4

Low

Mitigate

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 2 — Information Security Policy

ISO/IEC 27001:2022 — ISMS Core Policy

TechStart Inc.

Information Security Policy

ISO/IEC 27001:2022 — ISMS Core Policy

Document ID

TS-ISMS-POL-001

Version

1.0

Effective Date

Q3 2024

Owner

Chief Information Security Officer (CISO)

Approver

Chief Executive Officer

Review Cycle

Annual, or upon significant change to scope, technology, or regulation

Classification

Internal

References

ISO/IEC 27001:2022 Clause 5.2; ISO/IEC 27002:2022 A.5.1; NIST CSF ID.GV

1. Purpose

This policy establishes TechStart's commitment to protecting the confidentiality, integrity, and availability of information assets entrusted to us by our customers, employees, and partners. It defines the top-level direction for our Information Security Management System (ISMS) and sets the mandatory principles that all supporting policies, procedures, and controls must align with.

2. Scope

This policy applies to all TechStart employees, contractors, third parties, and any individual with access to TechStart information or information systems. It covers all information assets regardless of format or location, including but not limited to the customer database (5M+ records), the AWS production environment and all supporting SaaS tooling, developer and corporate endpoints, and any on-premises infrastructure retained post-migration.

3. Policy Statements

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

3.1 Leadership Commitment

Executive leadership is accountable for information security. The CEO approves this policy, and the CISO is responsible for day-to-day operation of the ISMS. Leadership will provide adequate resources, set measurable objectives, and review ISMS performance at least annually.

3.2 Risk-Based Approach

TechStart manages information security risk using a documented risk assessment methodology aligned to ISO 31000 and ISO/IEC 27005. Risks are identified, analyzed using a 5x5 likelihood-impact matrix, and treated according to defined risk appetite. Residual risks above Medium require documented owner acceptance; any residual Critical risk is escalated to the Board Risk & Audit Committee.

3.3 CIA Triad

TechStart protects information assets across three security objectives: Confidentiality (information is accessible only to authorized parties), Integrity (information is accurate and unaltered except through authorized processes), and Availability (authorized users have timely access to information and services consistent with stated SLAs).

3.4 Compliance and Regulatory Obligations

TechStart complies with applicable information security laws and regulations including but not limited to the EU General Data Protection Regulation (GDPR), California Consumer Privacy Act (CCPA), contractual obligations in customer Data Processing Agreements (DPAs), and any sector-specific requirements as they emerge. Legal and regulatory obligations are catalogued, reviewed quarterly, and reflected in the Statement of Applicability.

3.5 Cloud Security

TechStart operates primarily in AWS under a shared responsibility model. We will use AWS Well-Architected Security Pillar guidance, CIS AWS Foundations Benchmark controls, and Service Control Policies to enforce security boundaries between accounts, environments, and regions. Data residency is enforced at the Organization level.

3.6 Human Factors

All personnel receive information security awareness training on hire and annually thereafter. Roles with privileged access receive additional, role-specific training. Background checks are performed prior to granting access to production systems, consistent with applicable employment law.

3.7 Incident Response

TechStart maintains an Incident Response Plan. Security events are triaged, classified by severity, and responded to within defined time objectives. Breaches affecting personal data are reported to regulators and affected data subjects within the timelines required by GDPR Article 33-34 and other applicable law.

3.8 Continuous Improvement

The ISMS is subject to internal audit at least annually, management review at least annually, and ongoing monitoring of key risk and control indicators. Nonconformities are tracked to closure in the remediation tracker. The policy is reviewed annually or upon material change.

4. Roles and Responsibilities

Tejaswini Dondeti — Portfolio Sample
tejaswini.dondeti.grc.io
Tejaswini Dondeti — Portfolio Sample

Role

Responsibility

Accountability

Chief Executive Officer

Approves this policy; provides strategic direction and resources for the ISMS.

Ultimate accountability for information security outcomes.

Chief Information Security Officer

Owns the ISMS; drives risk assessment, policy development, and control implementation.

Accountable for ISMS performance and regulatory compliance.

Data Protection Officer

Advises on privacy obligations; oversees DPIA and records of processing.

Accountable for privacy compliance and data subject rights.

Engineering Leadership

Integrates security requirements into product and platform development.

Accountable for secure system design and secure coding.

Cloud Platform / SRE

Operates AWS security controls; responds to security events and incidents.

Accountable for cloud infrastructure security and monitoring.

All Employees and Contractors

Comply with this policy and supporting controls; report security events.

Responsible for individual compliance.

5. Enforcement

Violation of this policy may result in disciplinary action up to and including termination of employment or contract, and may be reported to law enforcement where appropriate. Suspected violations should be reported to the CISO or via the confidential reporting channel defined in the Incident Response Plan.

6. Related Documents

Access Control Policy (TS-ISMS-POL-002)

Data Classification & Handling Policy (TS-ISMS-POL-003)

Statement of Applicability (TS-ISMS-SOA-001)

Risk Register (TS-ISMS-RR-001)

Incident Response Plan (TS-ISMS-IRP-001)

7. Approval

Approved by:

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

_____

Chief Executive Officer

_____

Chief Information Security Officer

8. Revision History

Version

Date

Author

Change

1.0

Q3 2024

CISO / GRC Lead

Initial ISMS policy issued as part of cloud migration and ISO 27001 program.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 3 — Access Control Policy

ISO/IEC 27001:2022 Annex A.5.15–A.5.18, A.8.2–A.8.5

TechStart Inc.

Access Control Policy

ISO/IEC 27001:2022 Annex A.5.15 — A.5.18, A.8.2 — A.8.5

Document ID

TS-ISMS-POL-002

Version

1.0

Effective Date

Q3 2024

Owner

Cloud Platform Lead / CISO

Approver

Chief Information Security Officer

Review Cycle

Annual, or upon significant change to IAM architecture

Classification

Internal

References

ISO/IEC 27002:2022 A.5.15-18, A.8.2-5; NIST CSF PR.AC; CIS AWS Foundations v1.5

1. Purpose

This policy establishes the principles and requirements for granting, managing, and revoking access to TechStart information systems. It implements ISO/IEC 27001:2022 Annex A access control objectives and directly addresses risks R-01 (unauthorized database access) and R-02 (IAM misconfiguration) identified during the cloud migration risk assessment.

2. Scope

This policy applies to all access to TechStart information systems, including the AWS production and staging environments, corporate SaaS (Okta, GitHub Enterprise, Google Workspace, Jira/Confluence), developer tooling, and customer data. It covers human identities (employees, contractors) and non-human identities (service accounts, workload identities, CI/CD pipelines).

3. Principles

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Least Privilege: Access is granted only to the minimum set of resources and actions needed to perform a role.

Need to Know: Access to sensitive data is granted only when there is a documented business need.

Segregation of Duties: No single individual has end-to-end ability to provision, approve, and audit their own access to production.

Defense in Depth: Access controls are layered; perimeter, network, host, application, and data controls work together.

Zero Trust: No network location is inherently trusted. Every access request is authenticated and authorized.

Identity as Perimeter: Federated identity (Okta) is the primary control boundary; device posture is a secondary control.

4. Policy Requirements

4.1 Identity and Account Management

All human access to TechStart systems must use a unique, individually attributable identity federated through Okta. Shared accounts are prohibited except for break-glass emergency access, which is logged, alerted, and reviewed within 24 hours of use. Service accounts must be uniquely named, owned by a named team, documented in the service account register, and rotated according to the authentication requirements below.

4.2 Authentication

Multi-factor authentication (MFA) is mandatory for:

All access to the AWS Management Console.

All privileged CLI or API access (enforced via IAM condition keys).

All access to Okta itself, GitHub Enterprise, and any system handling Confidential or Restricted data.

Any access from outside the corporate network or unmanaged devices.

Passwords, where used, must meet the following minimum standards: at least 14 characters, screened against known-compromised password lists, stored hashed and salted (bcrypt, scrypt, or Argon2), and not reused across systems. Passwords for service accounts are replaced with short-lived credentials (IAM roles, OIDC, or workload identity) wherever technically possible.

4.3 Authorization

Access is granted using role-based access control (RBAC). IAM policies must:

Explicitly enumerate allowed Actions; wildcard Actions ("*") are prohibited except in break-glass policies.

Scope Resources to the minimum necessary ARN; wildcard Resources are prohibited for write actions on Restricted data.

Include Conditions enforcing MFA, source IP where applicable, and encryption-in-transit.

Be defined in Infrastructure as Code (Terraform) and reviewed through standard pull request workflow.

Privileged roles (those capable of modifying IAM, disabling CloudTrail, accessing the customer database directly, or elevating privileges) require just-in-time elevation with documented justification and are time-limited to 4 hours by default.

Tejaswini Donderti — Portfolio Sample
tejaswinidonderti.github.io
Tejaswini Donderti — Portfolio Sample

4.4 Provisioning, Modification, and Deprovisioning

Event

SLA

Process

New hire access

Grant within 1 business day of start date

HR triggers Okta provisioning via HRIS integration; manager approves role bundle in access request portal.

Role change

Grant new access and revoke old within 3 business days

Manager submits request; access reviewed by role-owning team.

Termination (voluntary)

Revoke within 4 hours of departure

HR triggers Okta deactivation; downstream apps deprovisioned via SCIM.

Termination (involuntary)

Revoke at time of notification

HR and manager coordinate with IT; session tokens invalidated.

Contractor end date

Revoke at end of contract, automated

Contract end date set in Okta; auto-deactivation on expiry.

Emergency revocation

Within 1 hour of request

CISO or designee initiates; documented in incident log.

4.5 Access Reviews

All human and non-human access to production systems is reviewed quarterly. Reviews are performed by the resource owner (e.g., DBA for database access, platform team for AWS roles), documented, and evidenced via IAM Access Analyzer reports and Okta access review campaigns. Findings must be remediated or accepted with owner signoff within 30 days of the review close.

4.6 Privileged Access

Privileged access to the production AWS environment requires:

Named individual identity (never shared), federated through Okta.

MFA and just-in-time role assumption.

Session logging via AWS Systems Manager Session Manager; command history retained for 1 year.

Periodic attestation by the role owner that the list of assumers remains appropriate.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

4.7 Logging and Monitoring

All access attempts — successful and failed — to production systems are logged via CloudTrail, VPC Flow Logs, and application audit logs. Logs are sent to a centralized, immutable store with 1-year hot and 7-year cold retention. Unusual access patterns (unusual geographic origin, out-of-hours privilege escalation, impossible travel) generate alerts routed to the on-call security engineer via PagerDuty.

5. Exceptions

Exceptions to this policy must be documented in the exception register, include a business justification, a compensating control, an owner, and a review date not exceeding 90 days. Exceptions are approved by the CISO and reviewed by GRC at the quarterly access review cycle.

6. Related Documents

Information Security Policy (TS-ISMS-POL-001)

Data Classification & Handling Policy (TS-ISMS-POL-003)

IAM Provisioning SOP (TS-ISMS-SOP-002)

Privileged Access Management SOP (TS-ISMS-SOP-003)

7. Approval

_____

Chief Information Security Officer

8. Revision History

Version

Date

Author

Change

1.0

Q3 2024

Cloud Platform Lead / GRC

Initial policy aligned to cloud migration and ISO 27001 SoA.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 4 — Data Classification & Handling Policy

ISO/IEC 27001:2022 Annex A.5.12, A.5.13, A.5.33, A.5.34, A.8.24

TechStart Inc.

Data Classification & Handling Policy

ISO/IEC 27001:2022 Annex A.5.12, A.5.13, A.5.33, A.5.34, A.8.24

Document ID

TS-ISMS-POL-003

Version

1.0

Effective Date

Q3 2024

Owner

Data Protection Officer (DPO)

Approver

Chief Information Security Officer

Review Cycle

Annual, or upon change in regulatory landscape

Classification

Internal

References

ISO/IEC 27002:2022 A.5.12-13, A.5.33-34, A.8.24; GDPR Articles 5, 25, 32; NIST CSF PR.DS

1. Purpose

This policy defines how TechStart classifies information assets by sensitivity and specifies the handling, storage, transmission, and disposal requirements for each classification tier. It supports our ISO/IEC 27001:2022 commitments and our obligations under GDPR, CCPA, and customer Data Processing Agreements.

2. Scope

This policy applies to all TechStart information in any form — electronic, printed, verbal, or visual — regardless of where it is stored or processed, including employee laptops, AWS environments, third-party SaaS, and physical office locations.

3. Classification Tiers

TechStart uses four classification tiers. When in doubt, information is classified at the higher tier until a formal classification is assigned.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Tier

Label

Definition

Examples

4

Restricted

Information whose unauthorized disclosure would cause severe harm to customers, individuals, or TechStart. Always includes personal data (PII).

Customer database (5M+ records); authentication secrets; private encryption keys; board materials.

3

Confidential

Information whose unauthorized disclosure would cause significant harm but does not typically include PII.

Source code; financial models; unreleased product plans; contracts; vendor pricing.

2

Internal

Information intended for internal TechStart audiences. Disclosure would cause limited harm.

Internal policies; organizational charts; meeting notes; Slack conversations.

1

Public

Information explicitly approved for public release.

Published marketing materials; public website; published privacy policy.

4. Handling Requirements

The following handling requirements apply to each tier. Stricter requirements always override less strict ones.

4.1 Labelling

Restricted and Confidential documents carry a visible classification label in the header.

Database schemas tag columns with classification metadata; the customer database is labelled Restricted at the table level.

Email containing Confidential or Restricted content includes the classification in the subject line (e.g., "[Confidential]").

4.2 Storage

Tier

Approved Storage

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Prohibited Storage

Restricted

Encrypted production databases (AWS RDS with KMS); encrypted S3 buckets with block-public-access; Okta vault for credentials.

Personal drives; unmanaged SaaS; physical paper without locked storage; non-production environments.

Confidential

Corporate Google Workspace (Drive with DLP); GitHub Enterprise private repositories; encrypted laptops.

Public GitHub; personal email; public Slack channels; personal laptops without MDM enrollment.

Internal

Corporate Google Workspace; Confluence; Slack private and internal channels.

Public internet; vendor forums; personal email.

Public

Any approved channel, including external marketing tools.

No restriction after approval.

4.3 Transmission

Restricted data must be encrypted in transit using TLS 1.2 or higher. Transfer to third parties requires a signed Data Processing Agreement or equivalent.

Confidential data must be encrypted in transit using TLS 1.2 or higher. Sharing outside TechStart requires approval from the data owner and a confidentiality agreement.

Internal data must be transmitted over authenticated, encrypted channels (corporate SaaS, VPN).

Public data may be transmitted via any channel.

4.4 Encryption

At rest: Restricted and Confidential data must be encrypted using AES-256 or stronger. AWS KMS customer-managed keys (CMKs) are used for Restricted data. Keys are rotated annually.

In transit: TLS 1.2 minimum; TLS 1.3 preferred. Deprecated protocols (SSLv3, TLS 1.0, TLS 1.1) are disabled at load balancers and endpoints.

In use: Sensitive computations involving Restricted data run in access-controlled production environments; no production data is copied to developer laptops.

4.5 Access

Access to each classification tier is governed by the Access Control Policy. Restricted data access is further subject to need-to-know approval, logging of every access event, and quarterly review. Bulk export of Restricted data (more than 1,000 records) requires DPO approval.

4.6 Retention and Disposal

Tier

Tejaswini Donneti — Portfolio Sample
tejaswinidonneti.github.io

Default Retention

Disposal Method

Evidence Required

Restricted

Per regulatory obligation and DPA; PII deletion within 30 days of lawful request.

Cryptographic erasure (key destruction) + deletion from all backups on next rotation.

Deletion record in ticketing system; backup rotation log.

Confidential

7 years for financial records; 2 years for operational.

Secure deletion; shredding for paper.

Deletion log for systems; shredding certificate for paper.

Internal

3 years default.

Standard deletion.

Not required individually; logged at system level.

Public

Indefinite.

N/A.

N/A.

5. Data Subject Rights (GDPR / CCPA)

TechStart honors data subject rights under GDPR (access, rectification, erasure, portability, restriction, objection) and equivalent CCPA rights. Requests are logged by the DPO, verified against the data subject's identity, and fulfilled within 30 days unless extended by law. Deletion requests result in cryptographic erasure of production records and removal from backups on the next rotation cycle.

6. Data Residency

Customer Restricted data is stored in regions consistent with customer contractual commitments. EU customer data is restricted to AWS regions within the European Union or equivalent adequacy jurisdictions, enforced at the AWS Organization level via Service Control Policies. Region assignments are documented in the Records of Processing Activities (ROPA).

7. Incidents Involving Classified Data

Any suspected unauthorized access, disclosure, or loss of Confidential or Restricted data must be reported to the CISO or the Security Incident Reporting channel within 1 hour of discovery. Incidents involving personal data are managed under the Incident Response Plan with special attention to GDPR Article 33-34 breach notification timelines.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

8. Training and Awareness

All employees complete data handling training on hire and annually thereafter. Roles with regular exposure to Restricted data receive additional training on GDPR, DPA obligations, and DPIA processes.

9. Related Documents

Information Security Policy (TS-ISMS-POL-001)

Access Control Policy (TS-ISMS-POL-002)

Records of Processing Activities (TS-ISMS-ROPA-001)

Data Protection Impact Assessment — Cloud Migration (TS-ISMS-DPIA-001)

10. Approval

_____

Data Protection Officer

_____

Chief Information Security Officer

11. Revision History

Version

Date

Author

Change

1.0

Q3 2024

DPO / GRC Lead

Initial policy issued as part of ISO 27001 program and cloud migration DPIA.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 5 — Risk Register & 5×5 Heat Map

Inherent and residual risk scores mapped to ISO 27001 Annex A and NIST CSF

Cover

TechStart Inc.	
Information Security Risk Register	
Cloud Migration Program — ISO/IEC 27001:2022 & NIST CSF	
Document ID:	TS-ISMS-RR-001
Version:	1.0
Assessment Date:	Q3 2024
Risk Owner:	CISO / GRC Lead
Scope:	Migration of 5M+ record customer database from on-premises to AWS; associated IAM, data pipeline, and business continuity workstreams
Methodology:	ISO 31000:2018 risk management; 5x5 likelihood × impact matrix; risk treatment per ISO/IEC 27005; controls mapped to ISO 27001:2022 Annex A and NIST CSF v1.1
Scoring:	Likelihood 1–5 (Rare → Almost Certain); Impact 1–5 (Negligible → Catastrophic); Risk Score = L × I; Risk Level: 1-4 Low, 5-9 Medium, 10-14 Medium-High, 15-19 High, 20-25 Critical
Acceptance:	Risk owner signoff required for all Critical and High residual risks; Board Risk & Audit Committee notified of any residual Critical
Risk Level Legend	
Critical (20-25)	Immediate action required; stop migration phase until treated
High (15-19)	Treat within current sprint; escalate to CISO
Medium-High (10-14)	Treat before cutover; formal treatment plan required
Medium (5-9)	Treat or accept with owner signoff; track in register
Low (1-4)	Accept and monitor; review annually
Risk Summary (live counts)	
Total risks identified:	-33
Inherent Critical:	2
Inherent High:	1
Residual Critical:	0
Residual High:	0

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

TechStart Inc.	
Residual Medium-High or below:	0

Register

Risk Register — TechStart Cloud Migration											
Risk ID	Risk Title	Risk Description	Asset Affected	Inherent Likelihood (1-5)	Inherent Impact (1-5)	Inherent Score	Inherent Level	Treatment Strategy	Control(s) — ISO 27001 Annex A	NIST CSF Function	Risk Owner
R-01	Unauthorized access to customer database during migration	Misconfigured IAM policies, weak credentials, or exposed endpoints during DMS migration expose 5M+ customer PII records to unauthorized access (external attacker or internal act...	Customer PII Database (RDS)	4	5	20	Critical	Treat (Mitigate)	A.5.15 Access control; A.5.17 Authentication information; A.8.2 Privileged access rights; A.8.5 Secure authentication ; A.8.24 Cryptography	Protect (PR.AC, PR.DS)	CISO / Cloud Platform Lead
R-02	IAM misconfig uration granting excessive privileges	Overly permissive IAM roles, wildcard actions, or forgotten break-glass accounts create paths to privilege escalation across the AWS Organization. A single misc onfiguration coul...	AWS IAM Identity Layer	4	5	20	Critical	Treat (Mitigate)	A.5.15 Access control; A.5.16 Identity management; A.8.2 Privileged access rights; A.8.3 Information access restriction	Protect (PR.AC); Detect (DE.CM)	Cloud Platform Lead

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Risk Register — TechStart Cloud Migration											
R-03	Data corruption during migration pipeline	DMS replication lag, schema mismatch, or network interruption causes data integrity loss (dropped rows, truncated fields) during the cutover window. Affects referential integrit...	DMS Migration Pipeline; Customer PII DB	3	5	15	High	Treat (Mitigate)	A.8.13 Information backup; A.8.14 Redundancy; A.5.30 ICT readiness for BC; A.8.24 Cryptography (integrity)	Protect (PR.DS); Recover (RC.RP)	DBA / Cloud Platform Lead
R-04	Data residency violation under GDPR / customer DPAs	Default AWS multi-region replication or misconfigured backup destinations send EU customer PII outside approved regions, violating GDPR Article 44-49 and contractual DPA terms. ...	Customer PII Database; Backup Snapshots	3	4	12	Medium-High	Treat (Mitigate)	A.5.31 Legal/regulatory requirements; A.5.34 Privacy and protection of PII; A.5.23 Information security for cloud services; A.8.10 Information deletion	Identify (ID.GV); Protect (PR.DS)	DPO / Legal

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Risk Register — TechStart Cloud Migration											
R-05	Service disruption during cutover window	Cutover fails or exceeds planned 4-hour window; customers experience outage exceeding SLA. Causes revenue loss, SLA credit obligations, and reputational damage. Rollback path ex...	Customer-facing SaaS Platform	3	4	12	Medium-High	Treat (Mitigate)	A.5.30 ICT readiness for BC; A.8.14 Redundancy; A.8.13 Information backup; A.5.24 Incident management	Respond (RS.RP); Recover (RC.RP)	VP Engineering
R-06	Insufficient logging and monitoring coverage post-migration	Gaps in CloudTrail, VPC Flow Log, or application log collection during transition mean security events in the new environment go undetected. First 90 days post-cutover are highe...	AWS Production Environment	3	4	12	Medium-High	Treat (Mitigate)	A.8.15 Logging; A.8.16 Monitoring activities; A.5.25 Assessment of security events	Detect (DE.CM, DE.AE)	SRE / Cloud Platform Lead

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Risk Register — TechStart Cloud Migration											
R-07	Vendor concentration and supply-chain dependency on AWS	Over-reliance on AWS creates single-provider risk; regional outage or policy change could disrupt service. Exit cost and portability are limited.	AWS Provider	2	4	8	Medium	Accept (with monitoring)	A.5.19 Supplier relationships; A.5.21 ICT supply chain; A.5.22 Monitoring of supplier services	Identify (ID.SC)	CISO / Legal

Heat Map - Inherent

5x5 Risk Heat Map — Inherent Risk						
Likelihood →						
		1 - Rare	2 - Unlikely	3 - Possible	4 - Likely	5 - Almost Certain
	5 - Catastrophic	5	10	R-03 (score 15)	R-01 R-02 (score 20)	25
	4 - Major	4	R-07 (score 8)	R-04 R-05 R-06 (score 12)	16	20
	3 - Moderate	3	6	9	12	15
↑ Impact	2 - Minor	2	4	6	8	10
	1 - Negligible	1	2	3	4	5
	Legend					
	Critical (20-25)					
	High (15-19)					
	Medium-High (10-14)					
	Medium (5-9)					
	Low (1-4)					

Heat Map - Residual

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

5x5 Risk Heat Map — Residual Risk (post-treatment)						
Likelihood →						
		1 - Rare	2 - Unlikely	3 - Possible	4 - Likely	5 - Almost Certain
	5 - Catastrophic	R-02 (score 5)	10	15	20	25
	4 - Major	4	R-01 R-07 (score 8)	12	16	20
	3 - Moderate	3	R-03 R-06 (score 6)	9	12	15
↑ Impact	2 - Minor	2	R-04 R-05 (score 4)	6	8	10
	1 - Negligible	1	2	3	4	5
	Legend					
	Critical (20-25)					
	High (15-19)					
	Medium-High (10-14)					
	Medium (5-9)					
	Low (1-4)					

Scoring Criteria

Likelihood and Impact Scoring Criteria			
Likelihood			
Rating	Label	Annual Probability	Description
1	Rare	< 5%	Event unlikely to occur during migration phase; no known precedent.
2	Unlikely	5–25%	Event could occur but requires coincidence of factors or motivated attacker.
3	Possible	25–50%	Event has occurred in comparable organizations; should be planned for.
4	Likely	50–75%	Event has occurred previously at TechStart or is common in cloud migrations.
5	Almost Certain	> 75%	Event is expected to occur without active control intervention.
Impact			
Rating	Label	Financial	Operational / Reputational / Regulatory

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Likelihood and Impact Scoring Criteria			
1	Negligible	< $10K	Minimal disruption; internal only; no regulatory or customer impact.
2	Minor	$10K–$100K	Short disruption (< 1h); minor customer inconvenience; internal remediation.
3	Moderate	$100K–$1M	Service degradation 1–4h; customer complaints; possible SLA credits.
4	Major	$1M–$10M	Outage > 4h; significant customer contract exposure; regulator notification; media coverage.
5	Catastrophic	> $10M	Mass data breach; regulatory fines (GDPR up to 4% global revenue); loss of customer trust; existential threat.

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 6 — Remediation Tracker

24-task remediation plan tracking risk treatment to closure

Cover

TechStart Inc.	
Risk Remediation Tracker	
Cloud Migration — ISO/IEC 27001:2022 Risk Treatment	
Document ID:	TS-ISMS-RT-001
Version:	1.0
Last Updated:	Q3 2024 (weekly review)
Owner:	GRC Lead / PMO
Linked Documents:	TS-ISMS-RR-001 Risk Register; TS-ISMS-SOA-001 Statement of Applicability
Review Cadence:	Weekly during migration; biweekly post-cutover; monthly steady-state
Escalation:	Any Blocked or P1 overdue item escalates to CISO; Board notification if unresolved > 30 days
Status Legend	
Not Started	
In Progress	
Blocked	
Completed	
Verified	
Summary (live counts)	
Total remediation items:	-47
Not Started:	4
In Progress:	4
Blocked:	0
Completed:	5
Verified:	12
Percent Complete:	-0.361702127659575

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.pub.to

Tracker

Risk Remediation Tracker											
Task ID	Linked Risk	Task Title	Description / Deliverable	Linked Control(s) — Annex A	Priority	Owner	Target Date	Completion Date	Status	% Complete	Evidence Link
T-001	R-01	Enforce MFA on all AWS console users	Okta-enforced MFA via SAML federation; no exceptions. ConfigureIAM deny-all-without-MFA policy.	A.5.17; A.8.5	P1 - Critical	Cloud Platform Lead	2024-08-15	2024-08-12	Verified	1	Okta admin export + IAM policy in Terraform PR #412
T-002	R-01	Deploy RDS encryption and KMS key policies	KMS CMK with least-privilege policy; RDS encryption at rest enabled; PI key rotation annual.	A.8.24; A.5.33	P1 - Critical	DBA	2024-08-20	2024-08-18	Verified	1	KMS key ARN + RDS modify-db log
T-003	R-01	Implement CloudTrail organization trail with S3 Object Lock	Org-wide CloudTrail to dedicated logging account; S3 bucket with Object Lock (WORM) 365-day retention.	A.5.28; A.8.15	P1 - Critical	SRE	2024-08-25	2024-08-24	Completed	1	CloudTrail ARN; S3 bucket policy
T-004	R-01	Database activity monitoring (DAM) rollout	Enable RDS enhanced monitoring + Performance Insights; forward anomalous queries to SIEM.	A.8.16; A.5.25	P2 - High	DBA / SRE	2024-09-30		In Progress	0.6	

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Risk Remediation Tracker											
T-005	R-02	Enable IAM Access Analyzer org-wide	Deploy Access Analyzer in all member accounts; findings routed to Security Slack channel.	A.5.15; A.8.2	P1 - Critical	Cloud Platform Lead	2024-08-10	2024-08-09	Verified	1	Access Analyzer console export; Terraform module
T-006	R-02	Implement Service Control Policies (SCPs)	Deny dangerous actions (root user access, disabling CloudTrail, modifying IAM without MFA) at Organization level.	A.5.15; A.8.22	P1 - Critical	Cloud Platform Lead	2024-08-15	2024-08-14	Verified	1	SCP JSON in IaC repo
T-007	R-02	Remove wildcard IAM policies from legacy roles	Audit all IAM policies, replace Action: "*" with scoped permissions; document exceptions.	A.8.2; A.8.3	P1 - Critical	Cloud Platform Lead	2024-08-30	2024-08-28	Completed	1	Policy diff report
T-008	R-02	Quarterly IAM access review process	Document process; first review scheduled post-cutover. Automated report via Access Analyzer + Okta report.	A.5.18	P2 - High	GRC Lead	2024-10-15		In Progress	0.4	
T-009	R-03	DMS replication validation with checksums	Enable DMS validation task; compare row counts and CRC checksums pre/post migration.	A.8.24; A.5.14	P1 - Critical	DBA	2024-09-05	2024-09-04	Verified	1	DMS validation report

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Risk Remediation Tracker											
T-010	R-03	Multi-AZ RDS with automated backups (35-day)	Deploy RDS in Multi-AZ with automated backup retention 35 days; cross-region snapshot copy to us-west-2.	A.8.13; A.8.14; A.5.30	P1 - Critical	DBA	2024-08-18	2024-08-16	Verified	1	RDS config; snapshot-copy rule
T-011	R-03	Quarterly restore test	Restore to isolated account, validate schema + row counts, document RTO achieved.	A.8.13; A.5.30	P2 - High	DBA	2024-10-30		Not Started	0	
T-012	R-04	Region-lock SCP for EU customer data	SCP denies resource creation outside approved regions (us-east-1, us-west-2 for US; eu-central-1 for EU).	A.5.31; A.5.23	P1 - Critical	Cloud Platform Lead / DPO	2024-08-22	2024-08-20	Verified	1	SCP JSON; DPIA update
T-013	R-04	Complete DPIA for cloud migration	GDPR Article 35 DPIA; reviewed by DPO and Legal; filed with ROPA.	A.5.34	P1 - Critical	DPO	2024-08-10	2024-08-08	Verified	1	DPIA v1.2 signed; ROPA entry #D-2024-014
T-014	R-04	Update customer DPAs with new sub-processor list	Notify customers of AWS as processor under GDPR Art. 28; update DPA where required.	A.5.20; A.5.31	P2 - High	Legal	2024-09-30		In Progress	0.7	

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Risk Remediation Tracker											
T-015	R-05	Cutover runbook with rollback steps	Written runbook, rehearsed twice; explicit rollback trigger criteria and timings documented.	A.5.29; A.5.30	P1 - Critical	VP Engineering	2024-09-15	2024-09-12	Verified	1	Runbook v2.0; dress rehearsal log
T-016	R-05	Customer co mmunication plan	Advance notice 30/14/7/1 day; status page; support team scripted.	A.5.24; A.5.26	P2 - High	Customer Success / Legal	2024-09-10	2024-09-08	Completed	1	Comm plan; draft emails approved
T-017	R-05	Incident response tabletop exercise	Simulate cutover failure, rollback decision, and customer escalation. Document lessons learned.	A.5.26; A.5.27	P2 - High	CISO / VP Eng	2024-09-18	2024-09-17	Verified	1	Tabletop after-action report
T-018	R-06	Deploy centralized log aggregation	All CloudTrail, VPC Flow, and application logs to central S3 + SIEM; 365-day hot + 7-year cold retention.	A.8.15	P2 - High	SRE	2024-10-31		In Progress	0.5	
T-019	R-06	GuardDuty org-wide with auto-remediati on	GuardDuty enabled in all regions and accounts; critical findings trigger Lambda remediation + PagerDuty.	A.8.16; A.5.25	P2 - High	SRE	2024-09-25	2024-09-22	Completed	1	GuardDuty config; Lambda ARN

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Risk Remediation Tracker											
T-020	R-06	90-day post-migration monitoring review	Structured review of all security events during first 90 days post-cutover; lessons learned report.	A.5.27; A.8.16	P3 - Medium	GRC Lead	2024-12-15		Not Started	0	
T-021	R-07	Document cloud exit strategy	Written exit plan: data egress process, alternative provider shortlist, estimated cost and timeline.	A.5.19; A.5.22	P3 - Medium	CISO	2024-11-30		Not Started	0	
T-022	Cross	Publish Information Security Policy	Approve and publish core ISMS policy; distribute to all staff; confirm attestation.	A.5.1	P2 - High	CISO	2024-09-01	2024-08-30	Verified	1	Policy v1.0 signed by CEO
T-023	Cross	Publish Access Control Policy	Document and distribute; link to IAM SOPs.	A.5.15; A.5.18	P2 - High	CISO	2024-09-05	2024-09-03	Verified	1	Policy v1.0
T-024	Cross	Publish Data Classification Policy	Document classification tiers and handling requirements; train staff.	A.5.12; A.5.13	P2 - High	DPO	2024-09-10	2024-09-08	Completed	1	Policy v1.0
T-025	Cross	Conduct ISO 27001 internal audit	Internal audit against ISMS; document findings; close out before external pre-a ssessment.	A.5.35; A.5.36	P3 - Medium	GRC Lead	2025-02-28		Not Started	0	

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

By Risk

Remediation Coverage by Risk					
Risk ID	Total Tasks	Verified/Completed	In Progress	Not Started/Blocked	% Closure
R-01	4	3	1	0	0.75
R-02	4	3	1	0	0.75
R-03	3	2	0	1	0.666666666666667
R-04	3	2	1	0	0.666666666666667
R-05	3	3	0	0	1
R-06	3	1	1	1	0.333333333333333
R-07	1	0	0	1	0
Cross	4	3	0	1	0.75

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample

Section 7 — Statement of Applicability (SoA)

ISO/IEC 27001:2022 — 93 Annex A controls assessed for applicability

Cover

TechStart Inc.	
Statement of Applicability (SoA)	
ISO/IEC 27001:2022 Annex A Controls	
Document ID:	TS-ISMS-SOA-001
Version:	1.0
Effective Date:	Q3 2024
Owner:	Information Security / GRC
Scope:	Cloud migration from on-premises to AWS; customer PII database (5M+ records); B2B SaaS platform supporting 500 employees
ISMS Boundary:	AWS production environment (us-east-1 primary, us-west-2 DR); DMS migration pipeline; IAM identity layer; CloudTrail/GuardDuty monitoring; data residency enforcement via SCPs
Standards Referenced:	ISO/IEC 27001:2022; ISO/IEC 27002:2022; NIST CSF v1.1; GDPR Article 32; AWS Well-Architected Security Pillar
Risk Register Linkage:	R-01 Unauthorized DB Access | R-02 IAM Misconfiguration | R-03 Data Corruption in Transit | R-04 Data Residency Violation | R-05 Cutover Outage
Legend	
Applicable	Yes = Control is relevant to ISMS scope; No = Control excluded with justification
Implementation Status	Implemented | Partially Implemented | Planned | Not Applicable
Justification	Rationale for applicability decision, tied to scope, risks, or regulatory obligations
Evidence / Reference	Artifact, policy, system, or configuration demonstrating control operation
Linked Risk(s)	Risk register entries addressed by this control
Summary (live counts from Controls sheet)	
Total Annex A controls:	93
Applicable (Yes):	92
Not Applicable:	1
Implemented:	60
Partially Implemented:	27

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.com/ro
Tejaswini Dondeti — Portfolio Sample

TechStart Inc.	
Planned:	5
Not Applicable (status):	1

Controls

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
Control ID	Control Name	Theme	Applicable (Yes/No)	Implementation Status	Justification	Evidence / Reference	Linked Risk(s)	Control Owner
A.5.1	Policies for information security	A.5 Organizational	Yes	Partially Implemented	Core to ISMS; required for the cloud migration program and ongoing SaaS operations.	Information Security Policy v1.0 (drafted as part of this engagement); Policy approval log pending executive sign-off.	R-01, R-02	CISO / GRC Lead
A.5.2	Information security roles and responsibilities	A.5 Organizational	Yes	Implemented	RACI established for migration; CISO, DPO, Cloud Platform Lead, DBA, and Engineering Manager roles defined.	Project RACI matrix; Risk Assessment Report §3 Governance.	R-01, R-02, R-03	CISO / GRC Lead
A.5.3	Segregation of duties	A.5 Organizational	Yes	Implemented	Required for AWS production access; prevents single-actor migration changes.	IAM role separation (migration engineer vs. approver); change approval workflow in Jira.	R-02	Cloud Platform / SRE
A.5.4	Management responsibilities	A.5 Organizational	Yes	Implemented	Executive sponsor assigned; migration steering committee meets biweekly.	Steering committee minutes; executive sign-off on risk treatment plan.	R-01, R-02, R-03, R-04, R-05	CISO / GRC Lead
A.5.5	Contact with authorities	A.5 Organizational	Yes	Partially Implemented	Required for GDPR/CCPA breach notification obligations given 5M+ PII records.	DPO contact register; draft breach-notification playbook.	R-01, R-04	Data Protection Officer

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github
Tejaswini Dondeti — Portfolio Sample

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.5.6	Contact with special interest groups	A.5 Organizational	Yes	Planned	AWS Security Bulletins, ISACA, and SANS subscriptions scheduled for ISMS operational phase.	Planned subscription list in ISMS operating plan.	R-01	CISO / GRC Lead
A.5.7	Threat intelligence	A.5 Organizational	Yes	Planned	AWS GuardDuty feeds to be consumed into SIEM post-migration; manual review in interim.	GuardDuty enablement ticket; SIEM onboarding backlog item.	R-01, R-02	Cloud Platform / SRE
A.5.8	Information security in project management	A.5 Organizational	Yes	Implemented	Migration project embedded security from design phase; this risk assessment itself is the evidence.	Risk Assessment Report; security checkpoints in migration runbook.	R-01, R-02, R-03, R-04, R-05	CISO / GRC Lead
A.5.9	Inventory of information and other associated assets	A.5 Organizational	Yes	Implemented	Critical assets catalogued: customer PII DB, DMS pipeline, IAM identity layer.	Asset inventory (Risk Assessment Report §4).	R-01, R-03	Cloud Platform / SRE
A.5.10	Acceptable use of information and other associated assets	A.5 Organizational	Yes	Partially Implemented	Existing AUP carried over; AWS-specific acceptable use being appended.	Current AUP; AWS acceptable use addendum (draft).	R-02	CISO / GRC Lead
A.5.11	Return of assets	A.5 Organizational	Yes	Implemented	HR offboarding process includes laptop return and SSO deprovisioning.	Offboarding checklist; SSO deprovisioning SLA.	R-02	HR / People Ops
A.5.12	Classification of information	A.5 Organizational	Yes	Implemented	Four-tier scheme applied: Public / Internal / Confidential / Restricted (PII).	Data Classification & Handling Policy v1.0.	R-01, R-03, R-04	Data Protection Officer

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.5.13	Labelling of information	A.5 Organizational	Yes	Partially Implemented	Database columns tagged with classification metadata; document labelling rolling out.	RDS tag schema; Confluence label template.	R-01, R-03	Data Protection Officer
A.5.14	Information transfer	A.5 Organizational	Yes	Implemented	DMS pipeline uses TLS 1.2+; customer data transfers governed by DPA addenda.	DMS endpoint config; signed DPAs with top 10 customers.	R-03, R-04	Cloud Platform / SRE
A.5.15	Access control	A.5 Organizational	Yes	Implemented	Role-based access enforced via AWS IAM and SSO; directly addresses R-01 and R-02.	Access Control Policy v1.0; IAM role definitions.	R-01, R-02	Cloud Platform / SRE
A.5.16	Identity management	A.5 Organizational	Yes	Implemented	Okta SSO federated to AWS; unique identities per human and workload.	Okta-AWS federation config; service account register.	R-01, R-02	Cloud Platform / SRE
A.5.17	Authentication information	A.5 Organizational	Yes	Implemented	MFA enforced for all AWS console users and privileged CLI access.	IAM MFA policy; Okta MFA enforcement report.	R-01, R-02	Cloud Platform / SRE
A.5.18	Access rights	A.5 Organizational	Yes	Partially Implemented	Quarterly access reviews defined; first review scheduled post-cutover.	Access review calendar; IAM Access Analyzer findings.	R-01, R-02	Cloud Platform / SRE
A.5.19	Information security in supplier relationships	A.5 Organizational	Yes	Partially Implemented	AWS (processor) assessed via SOC 2 Type II; DMS sub-processor approved.	AWS SOC 2 report on file; vendor risk register entry.	R-04	Legal / Compliance
A.5.20	Addressing information security within supplier agreements	A.5 Organizational	Yes	Implemented	AWS Enterprise Agreement and DPA executed; security clauses reviewed by Legal.	Executed AWS EA; DPA with GDPR Article 28 clauses.	R-04	Legal / Compliance

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.5.21	Managing information security in the ICT supply chain	A.5 Organizational	Yes	Partially Implemented	Primary dependency is AWS; secondary dependencies (CDN, SSO) tracked in vendor register.	Vendor register; dependency map.	R-01, R-04	Legal / Compliance
A.5.22	Monitoring, review and change management of supplier services	A.5 Organizational	Yes	Planned	Annual SOC 2 refresh cycle defined; first review scheduled 12 months post-migration.	Vendor review calendar.	R-04	Legal / Compliance
A.5.23	Information security for use of cloud services	A.5 Organizational	Yes	Implemented	AWS Well-Architected Security Pillar review completed; CIS AWS Foundations benchmark applied.	Well-Architected review report; Config conformance pack.	R-01, R-02, R-04	Cloud Platform / SRE
A.5.24	Information security incident management planning and preparation	A.5 Organizational	Yes	Partially Implemented	Incident Response Plan drafted; tabletop scheduled pre-cutover.	IR Plan v0.9; tabletop exercise plan.	R-01, R-05	CISO / GRC Lead
A.5.25	Assessment and decision on information security events	A.5 Organizational	Yes	Partially Implemented	GuardDuty alerts triaged by on-call SRE with security escalation criteria.	Triage runbook; PagerDuty escalation policy.	R-01, R-05	Cloud Platform / SRE
A.5.26	Response to information security incidents	A.5 Organizational	Yes	Partially Implemented	Severity-based response playbooks under development for top 5 scenarios.	IR playbooks (data breach, ransomware, misconfig).	R-01, R-05	CISO / GRC Lead
A.5.27	Learning from information security incidents	A.5 Organizational	Yes	Planned	Post-incident review template defined; to be exercised after first event or tabletop.	PIR template.	R-01, R-05	CISO / GRC Lead
A.5.28	Collection of evidence	A.5 Organizational	Yes	Partially Implemented	CloudTrail + S3 Object Lock configured for forensic retention (1 year, WORM).	CloudTrail config; S3 bucket policy.	R-01, R-02	Cloud Platform / SRE

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.5.29	Information security during disruption	A.5 Organizational	Yes	Partially Implemented	Cutover runbook includes rollback path; broader BCP refresh scheduled Q4 2024.	Cutover runbook v2; BCP project charter.	R-05	CISO / GRC Lead
A.5.30	ICT readiness for business continuity	A.5 Organizational	Yes	Implemented	Multi-AZ RDS with automated backups; documented RTO 4h / RPO 1h for cutover window.	RDS Multi-AZ config; BC/DR requirements doc.	R-03, R-05	Cloud Platform / SRE
A.5.31	Legal, statutory, regulatory and contractual requirements	A.5 Organizational	Yes	Implemented	GDPR, CCPA, and customer DPA obligations catalogued; data residency enforced via SCPs.	Legal obligations register; SCP policy set.	R-04	Legal / Compliance
A.5.32	Intellectual property rights	A.5 Organizational	Yes	Implemented	Open-source license inventory maintained; no GPL in distributed code.	SBOM; license scan reports.		Legal / Compliance
A.5.33	Protection of records	A.5 Organizational	Yes	Implemented	Customer records encrypted at rest (KMS) and in transit (TLS); retention schedule defined.	KMS key policies; retention schedule.	R-01, R-03, R-04	Data Protection Officer
A.5.34	Privacy and protection of PII	A.5 Organizational	Yes	Implemented	DPIA completed for migration; 5M+ PII records covered under GDPR Article 35 threshold.	DPIA report; privacy notice v3.	R-01, R-03, R-04	Data Protection Officer
A.5.35	Independent review of information security	A.5 Organizational	Yes	Planned	External ISO 27001 pre-assessment scheduled six months post-migration.	Engagement letter (planned).		CISO / GRC Lead
A.5.36	Compliance with policies, rules and standards for information security	A.5 Organizational	Yes	Partially Implemented	Quarterly control self-assessments initiated; first cycle Q4 2024.	CSA template; compliance calendar.		CISO / GRC Lead

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.5.37	Documented operating procedures	A.5 Organizational	Yes	Partially Implemented	Cutover runbook, IAM provisioning SOP, and backup/restore SOP documented; broader SOP library in progress.	Confluence ISMS SOP space.	R-02, R-03, R-05	Cloud Platform / SRE
A.6.1	Screening	A.6 People	Yes	Implemented	Background checks performed for all hires with production access.	HR screening policy; vendor background check records.	R-02	HR / People Ops
A.6.2	Terms and conditions of employment	A.6 People	Yes	Implemented	Employment contracts include confidentiality and IP clauses.	Standard employment contract template.		HR / People Ops
A.6.3	Information security awareness, education and training	A.6 People	Yes	Partially Implemented	Annual security awareness training in place; AWS-specific modules being added.	LMS training completion report; AWS module roadmap.	R-01, R-02	HR / People Ops
A.6.4	Disciplinary process	A.6 People	Yes	Implemented	HR disciplinary policy covers security violations.	HR policy §7 Disciplinary.		HR / People Ops
A.6.5	Responsibilities after termination or change of employment	A.6 People	Yes	Implemented	Offboarding checklist includes access revocation within 4 hours.	Offboarding SOP; SLA dashboard.	R-02	HR / People Ops
A.6.6	Confidentiality or non-disclosure agreements	A.6 People	Yes	Implemented	NDAs signed by all employees and third parties with PII access.	NDA register.	R-01, R-04	Legal / Compliance
A.6.7	Remote working	A.6 People	Yes	Implemented	Zero-trust access via SSO + MFA; managed endpoints required.	Remote work policy; MDM enrollment report.	R-02	Cloud Platform / SRE
A.6.8	Information security event reporting	A.6 People	Yes	Partially Implemented	Reporting channel exists; rolling out dedicated #security-report Slack channel and email alias.	IR Plan §4 Reporting; Slack channel setup ticket.	R-01, R-05	CISO / GRC Lead

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.7.1	Physical security perimeters	A.7 Physical	Yes	Implemented	AWS data centers inherit from AWS SOC 2; corporate office has card access.	AWS SOC 2; office access control system.		Facilities / IT Ops
A.7.2	Physical entry	A.7 Physical	Yes	Implemented	Badge + visitor log for corporate office; AWS inherited.	Visitor log policy; AWS shared responsibility.		Facilities / IT Ops
A.7.3	Securing offices, rooms and facilities	A.7 Physical	Yes	Implemented	Server closet decommissioned post-migration; office zones defined.	Facilities diagram; decommissioning record.		Facilities / IT Ops
A.7.4	Physical security monitoring	A.7 Physical	Yes	Implemented	CCTV in corporate office; AWS inherited.	CCTV policy.		Facilities / IT Ops
A.7.5	Protecting against physical and environmental threats	A.7 Physical	Yes	Implemented	AWS inherited; corporate office fire suppression and UPS in place.	Facilities maintenance log.		Facilities / IT Ops
A.7.6	Working in secure areas	A.7 Physical	Yes	Implemented	Production admin workstations kept in locked area when unattended.	Clean desk + secure area SOP.		Facilities / IT Ops
A.7.7	Clear desk and clear screen	A.7 Physical	Yes	Implemented	Automatic screen lock after 10 minutes; clean desk policy enforced.	MDM screen-lock config; clean desk policy.		Facilities / IT Ops
A.7.8	Equipment siting and protection	A.7 Physical	Yes	Implemented	No critical equipment on-prem post-migration; laptops secured.	Asset location register.		Facilities / IT Ops
A.7.9	Security of assets off-premises	A.7 Physical	Yes	Implemented	MDM-enrolled laptops with full-disk encryption.	MDM encryption report.	R-02	Facilities / IT Ops
A.7.10	Storage media	A.7 Physical	Yes	Implemented	Legacy on-prem media sanitized and destroyed with certificate.	Media destruction certificates.	R-03	Facilities / IT Ops

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io/portfolio-samples
Tejaswini Dondeti — Portfolio Sample

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.7.11	Supporting utilities	A.7 Physical	Yes	Implemented	AWS inherited for production; UPS and generator for corporate office.	Facilities contract.		Facilities / IT Ops
A.7.12	Cabling security	A.7 Physical	Yes	Implemented	Not material post-migration; office cabling meets code.	Facilities diagram.		Facilities / IT Ops
A.7.13	Equipment maintenance	A.7 Physical	Yes	Implemented	Laptops under vendor warranty; AWS inherited for servers.	Vendor warranty register.		Facilities / IT Ops
A.7.14	Secure disposal or re-use of equipment	A.7 Physical	Yes	Implemented	End-of-life laptops wiped via certified wipe; destruction certificate retained.	Disposal certificates.	R-03	Facilities / IT Ops
A.8.1	User end point devices	A.8 Technological	Yes	Implemented	MDM enforced; disk encryption and EDR mandatory on all endpoints.	MDM compliance dashboard.	R-02	Cloud Platform / SRE
A.8.2	Privileged access rights	A.8 Technological	Yes	Implemented	Privileged AWS roles require MFA + JIT via Okta; break-glass accounts logged and alerted.	Privileged Access SOP; break-glass register.	R-01, R-02	Cloud Platform / SRE
A.8.3	Information access restriction	A.8 Technological	Yes	Implemented	RDS access restricted to application role and DBA group; row-level controls for multi-tenant data.	IAM policy; application config.	R-01	Cloud Platform / SRE
A.8.4	Access to source code	A.8 Technological	Yes	Implemented	GitHub Enterprise with SSO; branch protection and code owners required.	GitHub org settings.	R-02	Engineering / Platform

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.8.5	Secure authentication	A.8 Technological	Yes	Implemented	MFA enforced via Okta for all workforce identities; service accounts use short-lived IAM credentials.	Okta config; IAM policy.	R-01, R-02	Cloud Platform / SRE
A.8.6	Capacity management	A.8 Technological	Yes	Implemented	RDS and EC2 autoscaling enabled; CloudWatch alarms on CPU, memory, IOPS.	CloudWatch alarms; runbook.	R-05	Cloud Platform / SRE
A.8.7	Protection against malware	A.8 Technological	Yes	Implemented	EDR on all endpoints; GuardDuty for AWS workload threats.	EDR dashboard; GuardDuty findings.	R-01	Cloud Platform / SRE
A.8.8	Management of technical vulnerabilities	A.8 Technological	Yes	Partially Implemented	Monthly vulnerability scans; patching SLAs defined (critical 7 days, high 30 days).	Vulnerability management SOP; scan reports.	R-01, R-02	Cloud Platform / SRE
A.8.9	Configuration management	A.8 Technological	Yes	Implemented	Infrastructure as Code (Terraform); AWS Config rules for drift detection.	Terraform repo; Config conformance pack.	R-02	Cloud Platform / SRE
A.8.10	Information deletion	A.8 Technological	Yes	Partially Implemented	Retention schedule aligned to legal requirements; automated deletion for audit logs > 1 year; customer deletion requests tracked.	Retention schedule; deletion runbook.	R-04	Data Protection Officer
A.8.11	Data masking	A.8 Technological	Yes	Partially Implemented	Non-production environments use synthesized data; production masking for support read-only roles in progress.	Data masking design doc.	R-01	Engineering / Platform

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.8.12	Data leakage prevention	A.8 Technological	Yes	Partially Implemented	S3 bucket public access blocked org-wide; DLP tooling for email in place; endpoint DLP under evaluation.	SCP deny-public; Google Workspace DLP config.	R-01, R-04	Cloud Platform / SRE
A.8.13	Information backup	A.8 Technological	Yes	Implemented	RDS automated backups (35-day retention); cross-region snapshot copy; restore tested quarterly.	Backup SOP; last restore test report.	R-03, R-05	Cloud Platform / SRE
A.8.14	Redundancy of information processing facilities	A.8 Technological	Yes	Implemented	Multi-AZ RDS; multi-region DR plan; target RTO 4h / RPO 1h.	HA architecture diagram; DR plan.	R-05	Cloud Platform / SRE
A.8.15	Logging	A.8 Technological	Yes	Implemented	CloudTrail org-wide; VPC Flow Logs; application logs to centralized log bucket with 1-year retention.	CloudTrail config; log retention policy.	R-01, R-02	Cloud Platform / SRE
A.8.16	Monitoring activities	A.8 Technological	Yes	Partially Implemented	GuardDuty + CloudWatch alarms; SIEM onboarding in progress.	GuardDuty config; SIEM backlog ticket.	R-01, R-02	Cloud Platform / SRE
A.8.17	Clock synchronization	A.8 Technological	Yes	Implemented	NTP via AWS time-sync service; endpoints use OS-managed NTP.	System config documentation.		Cloud Platform / SRE
A.8.18	Use of privileged utility programs	A.8 Technological	Yes	Implemented	Privileged utilities (psql, awscli) gated by IAM; session logging via SSM.	SSM session manager config.	R-01, R-02	Cloud Platform / SRE
A.8.19	Installation of software on operational systems	A.8 Technological	Yes	Implemented	Immutable AMIs; no interactive installs on production hosts.	AMI build pipeline.	R-02	Cloud Platform / SRE

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.8.20	Networks security	A.8 Technological	Yes	Implemented	VPC with private subnets; security groups least-privilege; VPC endpoints for S3/KMS.	Network diagram; SG audit.	R-01, R-02	Cloud Platform / SRE
A.8.21	Security of network services	A.8 Technological	Yes	Implemented	TLS 1.2+ enforced; AWS PrivateLink for inter-service; WAF in front of public endpoints.	WAF rules; TLS config.	R-01, R-03	Cloud Platform / SRE
A.8.22	Segregation of networks	A.8 Technological	Yes	Implemented	Production, staging, and corporate networks segregated via separate AWS accounts with SCPs.	AWS Organizations structure; SCP policies.	R-02	Cloud Platform / SRE
A.8.23	Web filtering	A.8 Technological	Yes	Implemented	Umbrella DNS filtering on managed endpoints; category-based blocking.	Umbrella console export.	R-01	Cloud Platform / SRE
A.8.24	Use of cryptography	A.8 Technological	Yes	Implemented	KMS-managed keys for RDS, S3, EBS; TLS 1.2+ for all in-transit data; key rotation annually.	KMS key policies; Cryptography SOP.	R-01, R-03, R-04	Cloud Platform / SRE
A.8.25	Secure development life cycle	A.8 Technological	Yes	Partially Implemented	Security requirements in design phase; threat modeling for new features; automated SAST in CI.	SDLC policy; SAST reports.	R-01	Engineering / Platform
A.8.26	Application security requirements	A.8 Technological	Yes	Partially Implemented	OWASP ASVS L2 targeted for customer-facing endpoints; auth/authz requirements in every story.	ASVS checklist; PR template.	R-01	Engineering / Platform

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github
Tejaswini Dondeti — Portfolio Sample
Tejaswini Dondeti — Portfolio Sample

ISO/IEC 27001:2022 Annex A — Statement of Applicability								
A.8.27	Secure system architecture and engineering principles	A.8 Technological	Yes	Implemented	Defense-in-depth, least privilege, and zero-trust documented as architecture tenets.	Architecture tenets doc.	R-01, R-02	Engineering / Platform
A.8.28	Secure coding	A.8 Technological	Yes	Partially Implemented	Secure coding guidelines published; peer review required; SAST gates in CI.	Coding guidelines; CI pipeline config.	R-01	Engineering / Platform
A.8.29	Security testing in development and acceptance	A.8 Technological	Yes	Partially Implemented	SAST + SCA in CI; DAST scheduled quarterly; annual external penetration test.	Latest pentest report.	R-01	Engineering / Platform
A.8.30	Outsourced development	A.8 Technological	No	Not Applicable	No outsourced development; all code written in-house.	N/A — excluded based on scope.		Engineering / Platform
A.8.31	Separation of development, test and production environments	A.8 Technological	Yes	Implemented	Separate AWS accounts for dev, staging, production; no prod data in lower envs.	AWS Organizations diagram.	R-02, R-03	Cloud Platform / SRE
A.8.32	Change management	A.8 Technological	Yes	Implemented	All production changes via PR + CAB review; emergency changes logged and reviewed post-hoc.	CAB charter; change log.	R-02, R-05	Cloud Platform / SRE
A.8.33	Test information	A.8 Technological	Yes	Partially Implemented	Synthesized or masked data in test environments; no production PII copied down.	Data masking SOP.	R-01	Engineering / Platform
A.8.34	Protection of information systems during audit testing	A.8 Technological	Yes	Partially Implemented	Audit activities scheduled to avoid production cutover windows; read-only audit roles provisioned.	Audit coordination SOP.		CISO / GRC Lead

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io

Exclusions & Decisions

Applicability Decisions — Exclusions & Rationale			
Control ID	Control Name	Decision	Rationale
A.8.30	Outsourced development	Excluded (Not Applicable)	TechStart performs all software development in-house with salaried engineering staff. There is no outsourced development arrangement; therefore this control is not applicable to...

Tejaswini Dondeti — Portfolio Sample
tejaswinidondeti.github.io
Tejaswini Dondeti — Portfolio Sample